APPLICATION AND DATA SECURITY AND CONFIDENTIALITY

This attachment is for the purpose of ensuring adequate information security protection is in place at all times during this contract between the Department of Children and Families hereinafter referred to as "the Department" and service Providers, Providers, and information trading partners, all referenced hereinafter together referred to as "Providers" in this attachment.

In this document, the term "State Data" means any electronic information including, but not limited to, records, files, computer programs, and databases, that are owned by the State of Florida.

1. **Hosting Data or Applications** – This section applies to all contracts whereby a Provider is hosting data, or hosting an application that processes data, on behalf of the Department. Provider will comply with the following:

- **a.** Provider, its employees, subcontractors, and agents will comply with all security and administrative requirements of the Department in performance of this contract. Provider will provide immediate notice to the Department's Information Security Manager (ISM), or their designee, in the event it becomes aware of any security breach and any unauthorized transmission of State Data as described below or of any allegation or suspected violation of security requirements of the Department.
- **b.** Provider will produce, upon entering a contract, a current security audit (no more than 12 months old) performed by a third party that is certified to perform such audits that demonstrate the use of sound security measures and practices by the Provider hosting the data or application that is processing data, as defined by a nationally recognized security framework. Provider will produce the status of any corrective action plans underway to address deficiencies found in the security audit. Provider must provide an annual update on any open corrective action plans associated with the most recent audit's noted deficiencies. The Department has the right to require Provider to produce a new or updated audit every three (3) years during the contract term, at Provider's expense.
- **c.** Provider will provide a copy of its American Institute of Certified Public Accountants (AICPA) "Standards for Attestation Engagements no. 18" (SSAE 18) Service Organization Controls (SOC) Report, SOC #, Type #, to the Department within one month of issued Purchase Order. For each additional year of the contract, at the request of the Department, Provider will obtain a current American Institute of Certified Public Accountants (AICPA) "Standards for Attestation Engagements no. 18" (SSAE 18).
- **d.** Data Loss Prevention: Provider will perform periodic backups of all data (files, programs, databases, electronic records, etc.) hosted by Provider on behalf of the Department sufficient to ensure no data loss occurs, and that data will be restored from backup, when necessary, at the Provider's sole expense. In the event of loss of any State Data or records, where such loss is due to the negligence of Provider or any of its subcontractors or agents, the Department may be entitled to sanctions by law or financial consequences per the contract.
- **e.** Breach: A confirmed event that compromises the confidentiality, integrity or availability of information or data. In the event of a breach of any State Data where such breach is due to the negligence of Provider or any of its subcontractors or agents, the Department may be entitled to sanctions by law or financial consequences per the contract. Provider may be subject to administrative sanctions for failure to comply with section 501.171, Florida Statutes, for any breach of data, due to a failure to maintain adequate security, and responsible for any costs to the Department for the breach caused by Provider.
- **f.** Data Protection: No State Data or information will be stored in, processed in, or shipped to offshore locations or outside of the United States of America, regardless of method, except as required by law. Access to State Data will only be available to approved and authorized staff, including offshore Provider personnel, that have a legitimate business

need. Requests for offshore access will be submitted in accordance with the Department established processes and will only be allowed with express written approval from the Deputy Secretary of Operations. Third parties may be granted time-limited terminal service access to IT resources as necessary for fulfillment of related responsibilities with prior written approval by the ISM. Third parties will not be granted remote access via VPN, private line, or firewall holes, without an approved exemption. Requests for exceptions to this provision must be submitted to the ISM for approval. When remote access needs to be changed, the ISM will be promptly notified. Provider will abide by all Department and State of Florida data encryption standards regarding the transmission of confidential or confidential and exempt information. Documented encryption standards will be provided upon request. Offshore data access must be provided via a trusted method such as SSL, TLS, SSH, VPN, IPSec, or a comparable protocol approved by the ISM. Confidential information must be encrypted using an approved encryption technology when transmitted outside of the network or over a medium not entirely owned or managed by the Department.

g. Notice Requirement: Provider will notify the Department upon detection of anomalous or malicious traffic within the scope of contracted services. To the extent applicable, failure to notify the Department of events or incidents that result in breach will subject Provider to legal sanctions, financial consequences per the contract and/or any costs to the Department of such breach of security.

h. Data Retention: Provider must retain data as follows:

i. Copies: At contract termination or expiration, submit copies of all finished or unfinished documents, data, studies, correspondence, reports and other products prepared by or for Provider under the contract; submit copies of all State Data to the Department in a format to be designated by the Department in accordance with section 119.0701, Florida Statutes; shred or erase parts of any retained duplicates containing personal information of all copies to make any personal information unreadable.

ii. Originals: At contract termination or expiration--retain its original records, and maintain, in confidence to the extent required by law, Provider's original records in un-redacted form, until the records retention schedule expires and to reasonably protect such documents and data during any pending investigation or audit.

iii. Both Copies and Originals: Upon expiration of all retention schedules and audits or investigations and upon notice to the Department, destroy all State Data from Provider's systems including, but not limited to, electronic data and documents containing personal information or other data that is confidential and exempt under Florida public records law.

2. Application Provisioning – This section applies to all contracts whereby a Provider is making available a software application to be used by the Department for collecting, processing, reporting, and storing data. Provider's software application used for the Department's automation and processing must support, and not inhibit, each of the following Department security requirements:

a. Users must never share account passwords or allow other users to use their account credentials. Users are responsible for all activities occurring from the use of their account credentials.

i. Provider employees are responsible for safeguarding their passwords and other authentication methods by not sharing account passwords, email encryption passwords, personal identification numbers, smart cards, identification badges, or other devices used for identification and authentication purposes.

ii. Passwords will not be passed or stored in plain text. Passwords must be encrypted or secured by other means when stored or in transit.

b. Provider employees will be accountable for their account activity.
   i. Audit records will allow actions of users to be uniquely traced for accountability purposes.
   ii. User accounts must be authenticated at a minimum by a complex password. Provider accounts will require passwords of at least 14 characters to include at a minimum three of the four characteristics: an upper and lowercase letter, a number, and a special character.
   iii. Provider employees must log-off or lock their workstations prior to leaving the work area.
   iv. Workstations must be secured with a password-protected screensaver with the automatic activation feature set at no more than 10 minutes.

c. Provider employees must not disable, alter, or circumvent Department security measures.

d. Computer monitors must be protected to prevent unauthorized viewing.

e. Consultation involving confidential information must be held in areas with restricted access.

f. Confidential information must be printed using appropriate administrative, technical, and physical safeguards to prevent unauthorized viewing.

g. Access to data and information systems must be controlled to ensure only authorized individuals are allowed access to information and that access is granted upon a "need-to-know" basis only.

h. User accounts will be deleted or disabled, as appropriate, within 24 hours of employment termination, non-use of account for 60 consecutive days, or under direction of a manager or Personnel and Human Resource Management's notification of a security violation.

i. Confidential information will not be disclosed without proper authority. It is the responsibility of each member of the workforce to maintain the confidentiality of information and data. Any employee who discloses confidential information will ensure sufficient authorization has been received, the information has been reviewed and prepared for disclosure as required, and no revocation of the requesting document has been received.

j. All employees are responsible for protecting Department data, resources, and assets in their possession.

k. All employees are responsible for immediately notifying their local information security coordinator of any violation of Department security policies, or suspected/potential breach of security.

l. All employees will be knowledgeable of the classifications of data and information and the proper handling of data and information.

3. **Data Interchange** – This section applies to contracts whereby the Department will be sending data transmissions to, or receiving data transmissions from, a Provider for the purpose of independent processing. Examples includes: sending laboratory orders to a laboratory, receiving laboratory results, sending billing information to a clearing house, receiving billing results or notification of payment, sending vital statistics to the Social Security Administration, sending physician licensing information to Florida's Agency for Health Care Administration, receiving continuing education credit information for medical profession licensees, etc. Data interchange contracts must have a data sharing agreement in place. Provider will comply with the following:

a. Follow all Department and State of Florida data encryption standards regarding the transmission of confidential or confidential and exempt information between the Department and the Provider. Documented encryption standards will be provided upon request. All transmission of confidential or confidential and exempt data must utilize a protected protocol such as SSL, TLS, SSH, VPN, IPSec or a comparable protocol approved by the ISM.

b. Use of any connection to the Department's network will be for retrieving information delivered by the Department, or sending data to the Department, and not for any other access to resources on the Department's network.

c. Protect and maintain the confidentiality of all data, files, and records, deemed to be confidential or confidential and exempt, retrieved from the Department pursuant to this agreement. The user will immediately notify the Department's ISM of any loss or breach of information originating from the Department and retrieved by Provider.

4. **All IT Services** – This section applies to all contracts whereby a Provider is providing IT services to the Department.

a. Provider will protect and maintain the confidentiality of all data, files, and records, deemed to be confidential or confidential and exempt, acquired from the Department pursuant to this agreement. Except as required by law or legal process and after notice to the Department, Provider will not divulge to third parties any confidential information obtained by Provider or its agents, distributors, resellers, subcontractors, officers or employees in the course of performing contract work, including, but not limited to, security design or architecture, business operations information, or commercial proprietary information in the possession of the state or the Department.

REMAINDER OF PAGE INTENTIONALLY LEFT BLANK